

Meridian Retail Group

Third-Party Vendor Risk Assessment: Executive Report

This report summarizes the results of a third-party vendor risk assessment covering six vendors with access to Meridian Retail Group systems or data. Risk was scored using a Likelihood x Impact model aligned with NIST SP 800-30, and evaluated against ISO/IEC 27001, SOC 2, and NIST CSF 2.0 supply chain risk guidance.

Risk Distribution

Risk Tier	Vendor Count
Critical	3
High	1
Medium	1
Low	1

Top Risks Identified

Vendor	Risk Tier	Key Finding
PaySecure Processing	Critical	Expired SOC 2 report; shared API keys across environments; MFA not enforced on vendor portal
QuickShip Logistics	Critical	Security questionnaire outstanding 90+ days; no visibility into vendor's security controls
ChatAssist AI	Critical	Indefinite retention of customer PII in chat transcripts; no data lifecycle policy
InsightCRM Analytics	High	Production customer data used in test environments without masking

Key Observations

Two of six vendors carry Critical risk requiring immediate attention: PaySecure Processing, due to an expired SOC 2 report combined with weak access controls on a payment-data vendor, and QuickShip Logistics, due to a complete absence of security assessment evidence. ChatAssist AI, an AI-powered vendor, presents Critical risk tied to indefinite retention of customer PII with no defined data lifecycle policy. This is a growing concern, as AI vendors increasingly handle customer-facing data. Notably, PeopleFirst Payroll, despite handling the most regulated data category (SSNs, banking details), presents the lowest risk of all six vendors due to strong, independently verified controls. This illustrates that data sensitivity alone does not determine vendor risk; control maturity is the deciding factor.

Recommendations

1. Suspend new data sharing with QuickShip Logistics until its security questionnaire is completed and reviewed.
2. Require PaySecure Processing to provide a current SOC 2 report and remediate API key and MFA gaps prior to contract renewal.
3. Add data retention and deletion terms to the ChatAssist AI contract at next renewal.
4. Require InsightCRM Analytics to implement data masking for all non-production environments.
5. Establish an annual vendor re-assessment cycle for Critical- and High-tier vendors, and a biennial cycle for Medium- and Low-tier vendors.

Project Repository

The complete project, including the Vendor Risk Assessment workbook, supporting documentation, and project files, is available on GitHub:

github.com/anualabi4767/vendor-risk-assessment